BIZBOOSTER Gabon: Consolidated Audit (admin and frontend)

Repository dmouzou/bizbooster-gabon. Review date: 12 November 2026. Static, read-only review. Nothing was run, deployed or changed in your repository.

Scope read in full: `admin/`, `src/` (App, all 33 components, utils, services, data, types), `functions/src`, `firestore.rules`, `storage.rules`, `firebase.json`, indexes, CI workflows, `tests/`, `docs/`, `scripts/`, `scratch/`, root config. **Not read:** lockfiles, the binary `BIZBOOSTER_*` doc/PDF files, and `.agents/skills` (vendored official Firebase skills, hash-locked in `skills-lock.json`).

Severity: Critical = exploitable now or money/data at risk. High = serious, fix soon. Medium = real defect or risk. Low = hygiene. "Verify" = depends on production settings I cannot see.

1. Do these first

1. **Remove every Firebase Auth test phone number from the production project** [S1]. Static OTP codes are documented in the repo and two of the numbers belong to real accounts.
2. **Stop SMS-only password reset for ADMIN and SUPER_ADMIN accounts** [S2].
3. **Fix the ad-visibility bug** [F1]: only 3 hand-seeded accounts are "registered", so every other user's ads are flagged as test ads.
4. **Confirm the old plaintext-password cleanup ran** and consider a forced reset [S4].
5. **Put a gate on production deploys** [C1]: CI deploys rules and functions on every push to `main` with no rules tests and no approval.
6. **Fix the payment paths that can charge without delivering** [P1, P2, P3] and the webhook secret mismatch [P4].
7. **Use `setRole(USER)` to revoke admins, not the Firestore console** [S5].
8. **Protect CVs and ID images** [S6, S7] without deleting anything (ID images are kept, per your decision).
9. **Click "Signaler" on an ad** to confirm the likely `ReportAdModal` crash [U1].
10. **Make advertisers' view counts work** [F6].

2. Your decisions and what they imply

- **No free ads or boosters for new users** unless they come from an offer or coupon. Paid subscribers get free ads automatically. The server already does this (Standard quota 0). The dashboard, publish flow, CGU Art 4.2 and some tests still say Standard gets 3 free ads [L1].
- **Photo allowances follow the server:** 3 (Standard, Pro), 4 (Elite), 5 (Business). CGU Art 4.3 and `PRICING_CONFIG.includedImages` must match [L1].
- **The "Vérifié" badge on VIP/partner accounts is intentional.** Reword CGU Art 3.2 and the badge modal for partners [L2].
- **A permanent-block function must exist** (CGU Art 6 promises it). Not built yet [F9].
- **Gabon only for now.** Restrict phone auth and SMS regions to Gabon [S11].
- **Ads from registered users are always visible.** Only test ads are toggled by the Super Admin [F1].
- **Paying from any mobile money number is by design.** Only a per-number push rate limit remains [P12].
- **KYC ID images are kept after review.** Fixes below are access-control only [S7].
- **Rules changes must not break publishing** (a past change did). See Appendix A before touching any rule.
- **Password minimum stays at 6 characters.**
- **Lock `contactName` once an advertiser is KYC verified** [S16].

3. Corrections to my earlier messages

Withdrawn:

- The phone-suffix ownership check and the client-side SMS counter race (both only in dead duplicates under `admin/src`).
- The stale-URL KYC approval concern (the server compares the stored URL) and the booster-delta race (the server validates).
- Client-set `publishedAt` ranking manipulation (rules reject `publishedAt` and `moderatedAt` on create).
- "contactName has no validation on active ads" (rules allow only that one field, 1 to 80 characters).
- "`@types/react` missing" (it is installed).

Narrowed or changed:

- **Hook-order crashes.** I overstated this. A component that returns early before calling any hook is tolerated by React. Only `ReportAdModal` (six hooks before the early return, one after) is a likely real crash [U1]. `ShareAdModal`, `KycUploadModal`, `ExtendAdModal` and `AppAlertModal` should work but break lint rules.
- User-set `isTest` on create is overwritten by the server. Owners can still flip it on pending ads.
- Blank `walletId` overwrite is mitigated server-side; `isLive` can still flip [P11].
- Coin VIP is a placement perk, not free publication. The VIP unit bug is unreachable from the publish UI.
- Payer-number finding downgraded to Low.
- **Views fix changed:** do not copy `ad_counters` into `ads.viewsCount` on every view. That re-triggers every visitor's catalog listener (the problem your docs describe). See [F6].

4. Findings

4.1 Security and privacy

S1 [Critical] Production Auth test numbers with static OTP codes. `docs/rapport_console_firebase_phase1.md` lists test numbers with guessable six-digit codes. `docs/deploiement_et_recette_finale.md` says to log in with them. `FIREBASE_TEST_PHONE_NUMBERS` in `functions/src/index.ts` mirrors them. Two numbers also appear in `registeredPhones` (`scratch/init_system_config.cjs`), so they belong to real accounts, probably yours. Anyone who knows a number and its code can sign in, then use "Mot de passe oublié" to set a new password. *Fix:* delete all test numbers in Firebase Console > Authentication > Sign-in method > Phone; review those accounts' roles and recent `moderation_logs`, `gateway_audit` and payments; run `scripts/audit_security.ts`; reset passwords and revoke tokens; remove codes from docs, the "555555" OTP placeholder in `PhoneAuthModal` and the code; use the Auth emulator or a staging project for tests; decide whether to scrub git history.

S2 [High] SMS reset can take over admin accounts. `PhoneAuthModal` "Mot de passe oublié" needs only a phone OTP, then calls `updatePassword`. Admins sign in with the same phone-derived email, so SIM swap or SMS interception resets an admin. *Fix:* after the OTP, refuse reset when the account is ADMIN or SUPER_ADMIN (claim or doc); give admins email accounts with MFA. *Verify:* whether your admin accounts have the phone provider linked (email-only accounts are not affected).

S3 [High] Public identifiers, password-only login. The login email is derived from the phone number shown publicly on every ad. No App Check, no MFA. *Fix (keeping the 6-character rule):* enforce App Check (monitor mode first), alert on `auth/too-many-requests`, notify users of new logins, consider OTP step-up for sensitive actions.

S4 [High] Historic plaintext passwords. `scripts/migrate_auth_users.ts` used `userData.password` as the initial Auth password, so passwords were stored in Firestore documents. *Fix:* run `purge_password_fields.ts` in dry-run, confirm no `password` field remains, check backups, exports and point-in-time recovery for copies, and consider a forced reset for migrated users.

S5 [High] Revocation procedure and `setRole` are unsafe. The admin UI says to revoke a Super Admin in the Firestore console. Rules and Storage rules trust the `role` custom claim first, so editing the doc does not remove access. `setRole(USER)` is the correct path. `setRole` also accepts any transition (USER to ADMIN directly, demoting the last Super Admin or yourself); the UI restrictions are client-only. Revocation lags up to one hour (existing ID tokens stay valid). `assertSuperAdmin` in `functions` also accepts an `isSuperAdmin` claim/doc flag that the rules ignore. *Fix:* enforce transition rules and last-Super-Admin protection in `setRole`; fix the UI text; remove the `isSuperAdmin` side path.

S6 [High] CVs and job documents are effectively public. They are stored as tokenized `getDownloadURL()` links on the public ad doc, with `Cache-Control: public, immutable` for a year, and the publish form shows no privacy notice. The `cvs/` Storage rule (owner and admins only) does not apply to token URLs. *Fix:* store the Storage path; serve through a function that issues short-lived signed URLs (or require login); warn users; use private cache headers; migrate existing files.

S7 [High] KYC IDs use permanent tokenized links. Stored in `users.idDocumentUrl`. The upload modal says files are "chiffrés et consultés uniquement par les administrateurs", which is untrue for anyone holding a link. `approveKyc` checks only that the URL string equals the stored value and contains `kyc/<uid>/`, so a user can submit an external URL containing that text, and row-level approval skips the viewer and the view log. Original filenames go into the path; HEIC cannot be rendered by the admin `<img>`, so modal approval is blocked. *Fix (no deletion):* store the Storage path; let admins read via authenticated access or short-lived signed URLs; have `approveKyc` verify the object exists in the bucket; random filenames; convert HEIC client-side; move superseded files to a restricted archive path; reword the claim; require viewing before approval.

S8 [Medium] Untrusted URLs get through.

- `isValidStorageUrl` uses `pathname.includes('/b/<bucket>/')` (bypassable with another bucket), accepts bucket names without the `.appspot.com` suffix, and hardcodes a third bucket `bizbooster.appspot.com` you may not own.

- `isTrustedMediaUrl` accepts any `firebasestorage.googleapis.com` or `storage.googleapis.com` host.
- `PublishAdModal` and `EditAdModal` accept arbitrary pasted image URLs; `firebase.json` CSP allows `img-src https:`. *Fix:* validate on the server (`onAdCreated`, `resubmitAd`) that image URLs belong to this bucket under `ads/<uid>/`; tighten the helpers; drop the custom URL input and the Unsplash presets.

S9 [Medium] `deleteAd` storage cleanup can delete arbitrary objects. It extracts an object path from any URL in `images`, `videoUrl` or `cvUrl` regardless of bucket, so an attacker-supplied URL makes an admin deletion remove someone else's files. It misses `jobDocUrl` and nested CV URLs (orphaned PII). Owner deletes and removed CVs/photos trigger no cleanup. *Fix:* accept only URLs of this bucket under the owner's path, add an `onDocumentDeleted` cleanup, and delete replaced or removed user files through a function. (KYC images stay.)

S10 [Medium] Payment and moderation fields on public ads. Anyone can read `paidAmount`, `paymentMethod`, `transactionRef`, `paymentReference`, `reportsCount`, `suspensionReason` and owner-tier flags on every ACTIVE ad. Rules cannot filter fields on read. *Fix:* move them to a private subdocument written by functions (staged data migration). Do not attempt this with a rules change alone.

S11 [Medium] SMS abuse and cost. Any visitor can trigger SMS to any valid number (invisible reCAPTCHA only). Multi-country support is still enabled; the 3-per-15-minutes limit in `docs/capacite_quotas_et_alertes.md` is not implemented; `recordSmsSent` is unauthenticated (necessarily, since OTP happens before login). *Fix:* set the Auth SMS region policy to Gabon, restrict `isValidPhone` to Gabon, enforce App Check, rate-limit `recordSmsSent`.

S12 [Medium] Registration can be bypassed. After the OTP the user is already signed in. If they close the tab before setting a password, the session persists, the fallback profile reports `termsAccepted: true`, and they use the app with no profile, no password and no CGU acceptance. *Fix:* gate the app on the existence of `users/{uid}`, sign out incomplete sessions on load, stop fabricating `termsAccepted`.

S13 [Medium] Phone number not bound to the account. The `users` create rule lets a client write any `contactPhone` or `phoneNumber`. See Appendix A before changing it.

S14 [Medium] Contact phone is unverified. Step 2 checks only non-empty, then `toE164` formats it. No `isValidGabonMobile`, no OTP for custom numbers, `hasWhatsapp` hardcoded true. *Fix:* validate format; optionally verify custom numbers.

S15 [Medium] Reports abuse. `reporterPhone` is client-supplied; rules still allow direct client report creation, bypassing `reportAd`; no per-user rate limit; an `adId` containing `/` errors.

S16 [Medium] Verified badge is not tied to a verified name (decision: lock `contactName` after KYC). Plan: `approveKyc` stores `verifiedName`; `onAdCreated` and `resubmitAd` force `contactName = verifiedName` for verified owners; disable the name field in the profile tab, `EditAdModal` and the publish form for verified users; skip name changes in `handleUpdateUserProfile`; admin action for changes. A rules clause is optional and only after emulator tests.

S17 [Low] CSP and headers. CSP is Report-Only with no endpoint, uses `unsafe-inline`, and `connect-src` lacks `*.cloudfunctions.net` and the reCAPTCHA hosts. Enforcing it as written breaks callable functions and phone auth. The Permissions-Policy blocks camera and geolocation (check any use).

S18 [Low] Two admin entry points. `/admin` is served by the public app and by `bizbooster-admin`. The admin chunk loads for logged-out visitors. Remove one or gate it behind auth first.

S19 [Low] Image and Storage hygiene. `imageCompressor` returns the original when it is not smaller or on error (EXIF GPS kept), passes SVG through, cannot decode HEIC, always outputs JPEG and reads whole files as base64. `storage.rules` accept `image/svg+xml`, have no per-user quota, block client deletes, and use claim-only admin checks.

S20 [Low] Stored client data. Drafts (family and emergency contacts), preferences, viewed-ad history and seen-notification IDs stay in localStorage after logout; `sessionStorage.clear()` is not enough on shared devices. Interaction keys are never purged. No consent notice for profiling.

4.2 Payments and billing

P1 [High] FAILED is set on our own timeouts and is terminal. In `initiateSingPayPayment`, a timeout or network error marks the payment FAILED although the USSD push may have gone out, and `reconcilePayments` marks INITIATING for more than 2 minutes as FAILED. A later SUCCESS from the webhook is ignored: money taken, nothing delivered, no review queue. *Fix:* use PENDING or NEEDS_REVIEW, query SingPay by reference, allow FAILED to SUCCESS when the provider confirms.

P2 [High] Double-charge paths in the payment UI. When the local countdown reaches 0, `handleFinalExpired` unsubscribes from the `payments` listener; "Annuler" only closes the UI; "Réessayer" uses a new idempotency key. If the user already confirmed their PIN,

the first payment completes unseen and they pay twice. *Fix:* keep listening or poll the final status before declaring EXPIRED; block new initiation while a previous one is PENDING for the same product and ad; reuse the key on retry.

P3 [High] Media is uploaded after payment. `PublishAdModal.handlePaymentSuccess` uploads photos, video (up to 50 MB) and CV only after the money is taken. If an upload fails and the user closes the modal, `preGeneratedAdId` is lost; the payment is bound to that id, so a retry cannot reuse it. *Fix:* upload first, or persist `paymentReference`, adId and draft until publication succeeds, and add a retry/claim path (a server-side "attach payment" function also solves [P10]).

P4 [High] Webhook secret rotation breaks webhooks. `saveGatewayConfig` returns a URL with `?secret=...`; `singpayWebhook` reads only the `x-webhook-secret` header. `DEPLOYMENT.md` also documents `?secret=`. After rotation every webhook gets 401 and only the 2-minute reconcile settles payments. *Fix:* test with a real webhook; make code and docs agree; prefer a header or HMAC (secrets in URLs leak into logs).

P5 [Medium] Extras can be added without paying.

- Quota and exempt ads skip the image cap and keep `videoUrl`.
- The paid path does not strip `videoUrl` when video was not bought.
- `resubmitAd` allows 10 images.
- Pending ads are edited with a direct `updateDoc` that can add photos or video after payment. *Fix:* cap images and strip video in `onAdCreated` and `resubmitAd` from the quote.

P6 [Medium] Free-quota race. Parallel ad creates read the same `consumedFreeAdsCount`. Use a transaction.

P7 [Medium] Simultaneous-ad limits look client-only (3 / 8 / 14 / 20 via `requiresSubscription` metadata). *Verify* for a server cap in `onAdCreated`; add one.

P8 [Medium] Success is shown without confirming benefits. Dashboard purchases, boost purchases and `ExtendAdModal` call `pollSingPayStatus`, ignore the result and show success. NEEDS_REVIEW is unhandled, `reconcilePayments` re-polls the oldest 30 forever, and there is no admin payments view, alert or refund procedure. *Fix:* check `status` and `attributed`; add an admin "Payments to review" tab.

P9 [Medium] Extension flow. `requestExtension` after `settlePayment` already extended throws "already consumed". The free path accepts negative `days` and skips `durationDays`. `pendingExtension` is legacy: no function sets it and `approveAd` only accepts PENDING_REVIEW, so the admin "Valider l'extension" button always fails.

P10 [Medium] Ads stuck in PENDING_PAYMENT. The dashboard shows "À régulariser" with no pay action, `EditAdModal` blocks editing, and no server path moves the ad forward. Only deletion is possible.

P11 [Medium] Gateway configuration.

- The 10-saves-per-hour limit counts everything, so the kill switch (`isLive=false`) can be locked out.
- A 60-second per-instance cache delays kill-switch and rotation effects.
- Secrets are stored in plaintext in `private_config/singpay` .
- `migrateGatewayConfig` defaults `isLive` to true (fail-open) while the reader is fail-closed.
- The UI default `isLive: true` can flip payments live if the config failed to load.
- Re-auth for rotation never rotates: `pendingPayload` is set but unused, so the save runs instead.

P12 [Low] Initiation details. Zero-amount exempt/quota orders still call SingPay; the duplicate check is not atomic; the 8-digit length is validated only client-side; add a per-target-number push rate limit (payer-number choice is by design).

P13 [Medium] Prices are duplicated client-side. Tier prices, booster packs, boost price and the extension table are hardcoded in `UserDashboard` , `PublishAdModal` and `ExtendAdModal` (whose billing box uses the client price although a server quote is fetched). They match the server today (pricing tests) but will drift. Render from `previewQuote` .

P14 [Low] Stale closure on the tab-return success path. `MobilePaymentSimulator` 's `visibilitychange` effect has `[]` deps, so `onSuccess` can receive an empty phone, the default operator and a stale amount.

P15 [Low] Misleading payment UI. "SingPay Actif" badge shows regardless of `isLive` ; raw error messages; the Functions quota card is hardcoded (0 invocations, "CONFORME").

P16 [Low] Subscription details. `scheduledDowngradeTier` is a direct client write: *verify* the server never applies it without payment. Every subscription purchase resets `consumedFreeAdsCount` .

4.3 Cloud Functions and server logic

F1 [High] `isTest: !isRegistered` hides real ads. `onAdCreated` marks an ad as test unless the owner is in `settings/system_config.registeredUserIds` or `registeredPhones` . `scratch/init_system_config.cjs` seeds 3 users; the client sync was removed (comment S-13). Every other advertiser's ads are `isTest: true` , hidden from the public catalog (unless `showTestAds` is on, which also exposes demo ads with

real-looking phone numbers), from the Super Admin queue and from revenue figures. *Fix (your decision):* flag only genuine test content (seed IDs, explicit test accounts); delete the allowlist logic in `onAdCreated` and the client `isAdFromRegisteredAdvertiser`; backfill `isTest` for existing real ads (do not use `backfill.ts` as is, see [C6]).

F2 [Medium] `resubmitAd`. Ads without `userId` can be modified by any signed-in user; no validation of title, description, price, image URLs or `contactPhone` (bypasses create-time limits); the expiry clock keeps running during review; stale `rejectionReason`.

F3 [Medium] Moderation functions. "Suspendre" calls `rejectAd` (REJECTED from any status, boost not paused, no refund). `approveAd` and `rejectKyc` send no notification. Extension rejection uses the wrong notification type. `moderation_logs` does not match the `ModerationLog` type and has no UI.

F4 [Medium] Report data. `reportAd` stores a server timestamp, so the admin shows "Invalid Date"; it stores no `adTitle` or `adOwnerPhone`; the server writes `resolutionNote` while the UI reads `resolutionNotes`; `deleteAd` overwrites DISMISSED reports with RESOLVED; resolve and dismiss never decrement `reportsCount`.

F5 [Medium] Notifications. The client generates approval/rejection notices only while the app is open (no push, SMS or email). Persisting "seen" fails on server-created docs (rules allow owners to change only `isRead`), so seen state is device-local. `seenNotificationIds` and `favoriteAdIds` are unbounded arrays in the user doc.

F6 [Medium] View counts are broken end to end. `registerView` writes `ad_counters` only. Cards, the owner dashboard ("0 vues", "Vues Cumulées"), the "Plus consultées" sort, view-milestone notifications and the admin all read `ad.viewsCount`, which nothing updates. *Fix:* read `ad_counters` for owners and admins; sync into `ads.viewsCount` with an hourly scheduled function for sorting. Do not sync per view. Also: one hot doc per ad, unauthenticated callers can inflate counts (App Check).

F7 [Low] `vipCorner`. Units `an`, `trimestre` (MATERIEL) and `heure` (IMMOBILIER) fall through to the wrong threshold, but the publish UI cannot select them. A missing `propertyType` skips the type filter. Price is self-declared, so inflating it earns VIP placement. Client and server constants are duplicated.

F8 [Low] Smaller items. `boostAd` reads only `freeBoostsRemaining` (settlement falls back to `freeBoosts`); duplicate boost fields; tier `VIP` missing from the types (`SubscriptionUpgradeModal` crashes on it); `updateCounters` writes `system_counters/global` that nothing reads; `expireAds` comment says 3 free ads; hardcoded `us-central1`; callables return raw error messages; mixed timestamp types in `setSubscription`.

F9 [Medium] No block-user function. CGU Art 6 promises permanent blocking by phone number. *Build:* callable that disables the Auth user, revokes tokens, hides or suspends their ads and logs the action, plus an admin UI action and a block list checked at sign-up.

4.4 Frontend bugs and UX

U1 [High, verify] `ReportAdModal` **likely crashes on open.** It runs six `useState` hooks, then `if (!isOpen) return null`, then a `useEffect`. Opening it adds a hook and React throws "Rendered more hooks than during the previous render". Click "Signaler" on an ad to confirm. *Fix:* move the `useEffect` above the early return. `EditAdModal` already shows the safe pattern (outer wrapper returns null, inner component holds all hooks); apply it to `ShareAdModal`, `KycUploadModal`, `ExtendAdModal` and `AppAlertModal` too, to stay lint-clean.

U2 [High] The catalog does not scale. One unbounded realtime listener loads every ACTIVE ad for every visitor (N reads per visit, slow on mobile networks, cost grows with the catalog). Search, filters and sorting run client-side over all docs on every keystroke with no debounce. Cards render each photo twice at full upload size, with no thumbnails. *Fix:* paginated, category-scoped queries with `limit`; thumbnails (Resize Images extension or a function); `useDeferredValue` or debounce on search.

U3 [Medium] Error handling. No ErrorBoundary around `PublicApp` (only the admin branch has one). Lazy chunks have no failure handling, so a deploy that changes chunk names can blank the page for open tabs. `Header` calls `currentUser.name.split(' ')`, which throws if a profile has no name.

U4 [Medium] Contact name changes bypass moderation. Renaming the profile batch-updates `contactName` on all the user's ads, including ACTIVE ones (rules allow that single field, 1 to 80 characters). See [S16].

U5 [Medium] Deep links and shared URLs. A link needs the whole catalog loaded; a link to an expired, hidden or deleted ad silently does nothing; the `#ad-` hash parser only matches seed IDs; `hasProcessedUrlAdRef` prevents opening a second link. *Fix:* `getDoc` the ad and show "annonce introuvable".

U6 [Medium] Stock photos in real ads. The publish form offers Unsplash "photo test suggérée" presets, starts with one preset in state, and attaches a preset when the user adds no photo. If `hasVideo` is set with no file, a demo video is attached and billed. This misleads buyers and breaches CGU 2.2. Remove presets and require real media.

U7 [Medium] Prefilled defaults get published. Province, city and neighborhood default to Estuaire, Libreville and La Sablière, with price 350000, duration 15 days and type LOCATION; step 1 only checks that the neighborhood is non-empty. Neighborhood is free text with suggestions, so the neighborhood filter misses off-list values. Free-text fields

(neighborhood, necrology, avis, profession, experience, contactName) have no `maxLength`; the 1000-character description limit exists only in the UI (rules allow 4000, `resubmitAd` none). *Fix:* remove defaults or force an explicit choice; add limits.

U8 [Medium] Edit flow. `EditAdModal` also accepts arbitrary image URLs and a plain video link that `AdDetailModal` will not play. Removing a CV or photo does not delete the file [S9]. Switching `mainCategory` leaves stale category data in the document. Editing an ACTIVE ad takes it offline for moderation while the expiry clock keeps running. The form resets on every `ad` identity change (verify the parent passes a stable object). Notification "Corriger" can overwrite newer data with a stale ad object.

U9 [Medium] Missing filters. Bric-à-brac, Autres emplois, Avis de recherche and Événements have no filter bar, so no province or city filtering. `VehiclesFilterBar` has no location filter and no Motos/Vélos type filters (constants imported, unused). The five filter bars accept 4 to 5 duplicated prop names.

U10 [Medium] Interaction bugs. `AdCard` "Famille" and "Urgence" buttons call `contactPhone`, not the family or emergency contact. `VerifiedAdvertiserModal` is a portal inside the card, so clicking its overlay also opens the ad detail. A title click fires both title and card handlers. "Rebooster" in notifications only opens the detail view.

U11 [Medium] Mobile and accessibility. Modals do not push history, so Android Back leaves the site. `CategoryBar` drag-scroll fires a click on release and its wheel handler hijacks page scrolling. Most modals lack `role="dialog"`, Escape handling, focus trapping and `aria-label` on icon buttons; cards and KPI tiles are clickable divs.

U12 [Medium] SEO and share previews. The site is a SPA with generic Open Graph tags and no `og:image`, favicon, canonical, `robots.txt`, sitemap or manifest (`public/` holds two SVGs). Shared `/?ad=<id>` links show no ad title or photo in WhatsApp or Facebook, and ad pages are not indexable. *Fix:* a function that serves ad-specific meta tags (Hosting rewrite) plus a sitemap.

U13 [Low] Ranking and sorting. The lottery tolerance makes comparators non-transitive (non-deterministic order); `PRICE_DESC` does not normalize units (ASC does) and ASC ignores `heure` and puts free events last; interaction keys in localStorage are never purged; ranking uses the device clock; recency uses a time constant (~7 days) called a half-life.

U14 [Low] Copy and consistency. Hero says "100% Vérifié … toutes les annonces sont vérifiées" while CGU Art 5 says no goods control. "8 catégories" (there are 9) and "10 rubriques". Outdated hero, footer and meta category lists. `formatFCFA(NaN)` prints "NaN FCFA"; free categories show "0 FCFA"; under one hour shows "0h restantes"; raw enums

such as `MATERIEL_ROULANT` appear in share text. Developer notes show in auth errors ("Journalisez l'erreur complète..."). `MyAdsManager` shows "Section C - Cahier des charges" (and looks unused).

U15 [Low] Dead or duplicate code. `admin/src` duplicates 12 files from `src/` (several drifted; `ShareAdModal`, `firebase.ts`, `platformMetrics` among them). `indiaLocations.ts` duplicates `COUNTRY_LOCATIONS.IN`. Multi-country phone and location code is out of scope for now. Dependencies that look like scaffold leftovers: `express`, `dotenv`, `docx`, `pdfkit`, `esbuild`, `tsx`; `metadata.json` advertises `SERVER_SIDE_GEMINI_API`.

4.5 Admin panel

A1 [Medium] Roles are inconsistent across layers. `normalizeRole` accepts `admin`, `super-admin` and variants; Firestore rules accept only `ADMIN`, `SUPER_ADMIN`, `SUPER ADMIN`; Storage rules accept the claim only; `AdminPanel` compares raw `u.role`. `migrate_roles.ts` sets claims only for users whose role string changed, so already-normalized admins never get claims. *Fix:* backfill claims for all admins before relying on authenticated Storage reads.

A2 [Medium] Some statuses are invisible. SUSPENDED, EXPIRED and PENDING_PAYMENT ads have no filter, badge or reinstate action (only under "Toutes"), and the activity feed labels them all "Rejetée". The "Valider l'extension" button always fails [P9].

A3 [Medium] Business figures are not exact. The Observatoire sums `paidAmount` of every non-test ad (including REJECTED and unpaid PENDING_PAYMENT) while the moderation tab counts verified or ACTIVE ads only, so two different "Recettes" appear. Both derive from ad docs, not the `payments` collection, so deleting an ad removes its revenue and extension payments are missed. City rent averages mix day, month and year units; "Valeur Catalogue" adds unrelated prices; the "Emploi / Services" bucket holds every non-sale, non-rental ad; "Annonceurs" counts staff. Labels say "Chiffres Exacts" and "encaissés".

A4 [Medium] The quota dashboard is misleading. It frames the project as Spark while Cloud Functions require Blaze; the Functions card is hardcoded (0 invocations, "CONFORME", $0.00); no Firestore reads or writes are tracked even though the catalog listener and admin listeners are the likeliest cost driver; the "rapport d'ingénierie" claims CDN-served reads, Twilio/Infobip, Cloud SQL and JWT sessions that do not match the stack; `smsSentToday` is not compared with `todayDate` so yesterday's value shows as today; the server counts by UTC day, the client by Libreville day; counter resets are unaudited; storage figures are estimates; client counter writes fail for anyone but a Super Admin.

A5 [Medium] Admin listeners. `onSnapshot` on all of `ads`, `users` and `reports` with no limit loads every user's PII into memory and scales cost with data; listener errors are swallowed, so a permission error shows empty tables; claims are not force-refreshed after role changes.

A6 [Low] Admin UX. "Classer sans suite" and booster changes have no confirmation; reject reasons have no `maxLength`; tier labels are hardcoded; unknown operator shows "Moov Money"; the "Moov Actif" badge counts an unsaved secret; no UI for `moderation_logs`; reauth email falls back to `undefined@bizbooster.ga` if `phoneNumber` is missing.

A7 [Low] `admin/` build setup. Vite's root is `admin/`, so `VITE_FIREBASE_*` must live in `admin/.env`; a missing value throws at import (white screen, not caught by an ErrorBoundary). `vite.config` aliases react to `../node_modules/react`, which breaks a standalone install. Two lockfiles. `index.html` references a missing `/vite.svg`. The dev server binds `0.0.0.0`. `tsconfig` is not strict (also at the root).

4.6 Data model, rules and Storage

R1 [Medium] The rules test files contradict each other and are not in CI. In `firestore.rules.test.ts`, test 8 expects a VERIFIED user to be able to set `idVerificationStatus: 'PENDING'` with a new document while test 18 expects `PENDING` alone to fail; test 10 expects owner self-created notifications to succeed while test 19 expects them to fail. Run `npm run test:rules` against the emulator before any rules change.

R2 [Medium] Rule gaps (read Appendix A before acting). No value validation on owner updates of pending ads; owners can delete ACTIVE paid ads with no cleanup or refund warning; no user self-deletion; self-created notifications with free-form content; `ad_counters` allows public list; direct client report creation.

R3 [Medium] Unbounded user arrays. `favoriteAdIds` and `seenNotificationIds` grow without limit inside the user doc (1 MiB cap). *Verify* that `scheduledDowngradeTier` writes are intended [P16].

R4 [Low] Indexes. Query indexes are present. No TTL `fieldOverride` for `ad_views.expireAt` in `firestore.indexes.json` (*verify* in the console).

R5 [Low] Data hygiene.

- ISO strings and Firestore Timestamps are mixed (`subscriptionStartedAt`, `resubmittedAt`, `createdAt` on reports).
- Denormalized `ownerTier` and `isOwnerVerified` go stale on suspended, expired and pending-payment ads.

- `transactionRef` and `paymentReference` coexist.
- Seed data has 365-day durations with unrelated `paidAmount`, real-looking phone numbers and hotlinked images.
- `gabonLocations` has quality issues (for example a Woleu-Ntem town name listed under Nyanga, duplicated names, landmarks listed as neighborhoods).

4.7 CI/CD, configuration and process

C1 [High] Production deploys have no gate. Every push to `main` deploys Firestore rules, indexes, Storage rules, functions and live hosting. There is no staging, no approval and no rules tests (`npm test` excludes `firestore.rules.test.ts`). Hosting deploys before rules and functions, the opposite of `DEPLOYMENT.md`. Docs-only pushes redeploy everything. Given the earlier rules incident, this is the highest process risk.

C2 [High] Supply chain. `w9jds/firebase-action@master` (a floating third-party branch) receives a long-lived service-account JSON key stored in GitHub secrets; `FirebaseExtended/action-hosting-deploy@v0` is a floating tag; no `permissions:` blocks. *Fix:* pin actions by commit SHA, use workload identity federation, least-privilege roles.

C3 [Medium] PR previews use the production project, and a same-repo PR can edit the workflow and read the service-account secret. Use a staging project and environments with required reviewers.

C4 [Medium] CI quality. CI runs Node 20 (end of life) while `functions` engines say 24; function and rules tests are not run; `tests/functions_capacity.test.ts` needs build output (`dist-frontend`, `dist-admin`) that CI does not build before tests, so check whether `npm test` passes on a clean checkout. No Dependabot, CodeQL, secret scanning or CODEOWNERS.

C5 [Medium] Operations. No App Check, no documented backups or point-in-time recovery, no staging environment, no runbook for NEEDS_REVIEW payments or refunds, secrets stored in Firestore.

C6 [Medium] Scripts are risky to run.

- `migrate_auth_users.ts --cleanup-passwords` performs real deletes with no dry-run and wipes `phone_verifications`.
- Every script defaults to the production project with no emulator guard.
- `backfill.ts --commit` uses VIP thresholds that differ from `vipCorner.ts` and zeroes `viewsCount` above 10 times the median, so it would corrupt flags and wipe real counts; it also writes `backups/` full of ad PII that is not in `.gitignore`.

- `audit_security.ts` lists only the first 1000 Auth users and ignores `isSuperAdmin` claims.

C7 [Low] Repository hygiene.

- `scratch/` is committed, with real UIDs, phone numbers and a local path.
- `scripts/generate-doc.ts` embeds an old insecure `firestore.rules` (users could write their own role) in a "copy-paste into the console" document. Both generators write into `public/`, which Vite deploys to Hosting.
- `.firebaserc` also lists `global-af-dev` and `global-af-live` (wrong-project deploy risk).
- The package is still named `react-example`; `vite` is listed twice; both `bun.lock` and `package-lock.json` exist.
- `README.md` is the AI Studio template and there is no `.env.example`.

C8 [Low] Documentation drift. `DEPLOYMENT.md` (`expireAds` daily vs hourly, `?secret=` webhook, function list); `docs/audit-inconnues.md` (says `registerView` writes `viewsCount`, App Check inactive); `docs/capacite_quotas_et_alertes.md` (claims rate limits and App Check that I did not find implemented). The generated specification PDF mentions a supervisor PIN ("2410"); *verify* none exists in code.

4.8 Tests

T1 [Medium] Many tests do not test the code. `backfill`, `functions_logic` (encodes old quotas 3 / 8 / 15 / 30), `notifications_15s`, the queue simulation and scenarios 8, 16 and 17 re-implement logic inline. `functions_capacity` greps source text. `renderToString` tests cannot detect hook transitions (each call is a fresh mount), so the `ReportAdModal` crash is invisible. `real_time_analytics` uses fields that do not exist and locks in the "8 catégories" label. The personalization performance test is timing-based. `scripts/test_phone_utils.ts` is not run anywhere. Good tests: pricing, `settlePayment`, `resolveAdPayment`, personalization ranking, KYC URL checks, roles.

T2 [Low] Missing coverage. `initiateSingPayPayment` kill switch, webhook secret transport, `onAdCreated` flags and quota race, `approveKyc` path verification, `deleteAd` cleanup, `ReportAdModal` open/close.

4.9 Product and legal consistency

L1 [High] The CGU contradicts the implementation. Art 4.2 promises every user 3 free simultaneous ads (server: Standard quota 0). Art 4.3 says photos after the 5th are paid (server: 3 / 3 / 4 / 5). The dashboard says "Plan Standard Gratuit", "3 annonces incluses gratuitement" and "vos 3 plus anciennes restent en ligne" (the server suspends all quota-

based ads on expiry). Plan cards say both "8 annonces gratuites par mois (au-delà : facturées)" and "plafond de 8 annonces actives". "Badge vérifié Pro" suggests a paid plan buys verification. *Fix:* rewrite text to match the server rules you decided.

L2 [Medium] Verified-badge wording. Reword Art 3.2 and the badge modal for partner accounts ("Partenaire certifié BIZBOOSTER"). The modal claims "Identité vérifiée pour {contactName}" with an editable name [S16]. `isKycVerified` also returns true when `idVerifiedAt` is set after a rejection, or when a document URL exists with a non-PENDING status; use `idVerificationStatus === 'VERIFIED'`.

L3 [Medium] Other CGU gaps. Art 1 says Gabonese numbers only (accurate once multi-country code is removed) and the category list omits Prestations, Événements, Avis de recherche and Autres emplois. Art 7 names no data controller, retention period, user rights, KYC handling or localStorage profiling. Only a boolean `termsAccepted` is stored (no version, no server time). Art 6 blocking is not implemented [F9]. There is no refund or dispute process. The CGU contact uses `bizbooster-gabon.ga` while accounts use `bizbooster.ga` (*verify* you own both and their mail).

L4 [Low] Sensitive categories. Avis de recherche (missing persons, children) and Nécrologie (names of deceased) have no guidance or consent prompt; Cours à domicile has no vetting.

Appendix A. Changing rules without breaking publishing

Principles.

- Prefer server-side fixes (functions) over rules changes. Almost nothing above needs a rules change first.
- Make rules changes additive and small; deploy rules on their own, never bundled with code.
- Test with `npm run test:rules` and the functions emulator tests, then publish, edit, extend, report and upload KYC as a real test user in a **staging project** before production.
- Log the exact payload keys a real publish sends (emulator) and compare them with the rule before deploying; keep a one-command rollback ready.

What the client writes today (must stay allowed; confirm against `handleAdPublished` and `firestore.rules`).

- *Ad create:* `userId`, `title`, `description`, `price`, `status: 'PENDING_REVIEW'`, `durationDays`, `paymentReference`, plus the form fields (category, location, contact, images, category-specific blocks) and `createdAt`. Rules already reject `isFeatured`,

`boostRequested`, `expiresAt`, `publishedAt`, `moderatedAt` and payment-result fields on create.

- *User create (`PhoneAuthModal`):* `name`, `country`, `operator`, `role: 'USER'`, `termsAccepted`, `termsAcceptedAt`, `createdAt`, `contactPhone`, `phoneNumber`, `location`.
- *User update:* `name`, `location`, `favoriteAdIds`, `seenNotificationIds`, `scheduledDowngradeTier`, and the KYC fields (`idDocumentUrl`, `idDocumentType`, `idVerificationStatus: 'PENDING'`, `idSubmittedAt`, `idRejectionReason`).
- *Owner update on pending ads:* any content field; `contactName` on any status (1 to 80 characters, alone).
- *Self-created notifications* (`<uid>_<notifId>`) and owner `isRead` updates.

Low-risk changes (after staging tests).

- Close direct report creation (`ReportAdModal` already uses the callable).
- Make `ad_counters` readable by `get` only (the detail modal reads one doc); the owner dashboard then needs per-doc reads.
- Restrict Storage image types to JPEG, PNG and WebP only **after** the client converts HEIC and stops passing SVG through.

Do not do.

- Switch ad create or update to a strict `hasOnly([...])` list. Any new form field would block publishing.
- Try to hide fields on read with rules (impossible); use a private subdocument [S10].
- Bind phone numbers in the rules; use an `onCreate` trigger that overwrites the phone from the Auth record instead [S13].
- Remove owner updates on pending ads.

Appendix B. Coverage

Read in full: `admin/` (except lockfile), `firestore.rules`, `storage.rules`, `firebase.json`, `firestore.indexes.json`, `.firebaserc`, CI workflows, root config, all of `src/` (App, 33 components, utils, services, data, types), all of `functions/src` including tests, `tests/`, `docs/`, `scripts/`, `scratch/`, `public/`, `NOTES.md`, `DEPLOYMENT.md`, `README.md`, `skills-lock.json`.

Not read: lockfiles, binary `BIZBOOSTER_*` files, `.agents/skills`. This was a static review; findings marked *verify* need a check in your Firebase console, emulator or browser.

Appendix C. Suggested order of work

Today: [S1], [S2], [S4], pause CI deploys to `main` or add approval [C1], run `audit_security.ts`. **This week:** [F1] visibility fix, [P1] to [P4] payment integrity, [S5], [S6], [S7], [U1], [F6], [C2]. **Next two weeks:** [P3] and [P5] to [P10], [S8], [S9], [S10], [F9] block function, [S16] name lock, [L1] to [L3] text updates, staging project and rules tests in CI [C3], [C4]. **Later:** [U2] catalog pagination and thumbnails, [U12] share previews and SEO, [A3] and [A4] dashboard accuracy, test cleanup [T1], repository hygiene [C7], [C8].